

IAS-SAST-Scan Scan Report

Project Name	IAS-SAST-Scan
Scan Start	Friday, September 25, 2026 4:43:17 PM
Preset	Checkmarx Default
Scan Time	00h:01m:18s
Lines Of Code Scanned	10046
Files Scanned	23
Report Creation Time	Friday, September 25, 2026 5:26:13 PM
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199
Team	CxServer
Checkmarx Version	9.6.5.1001 HF9
Scan Type	Full
Source Origin	LocalPath
Density	1/100 (Vulnerabilities/LOC)
Visibility	Public

Filter Settings

Severity

Included: High, Medium, Low, Information
Excluded: None

Result State

Included: To Verify, Not Exploitable, Confirmed, Urgent, Proposed Not Exploitable
Excluded: None

Assigned to

Included: All

Categories

Included:

Uncategorized	None
Custom	None
PCI DSS v3.2.1	None
OWASP Top 10 2013	None
FISMA 2014	None
NIST SP 800-53	All
OWASP Top 10 2017	None
OWASP Mobile Top 10 2016	None
ASD STIG 4.10	None
OWASP Top 10 API	None
OWASP Top 10 2010	None
ASA Mobile Premium	None
ASA Premium	None

CWE top 25	None
MOIS(KISA) Secure Coding 2021	None
OWASP ASVS	None
OWASP Top 10 2021	All
SANS top 25	None
Top Tier	None
ASD STIG 5.3	None
Base Preset	None
OWASP Top 10 API 2023	None
PCI DSS v4.0	All
Excluded:	
Uncategorized	All
Custom	All
PCI DSS v3.2.1	All
OWASP Top 10 2013	All
FISMA 2014	All
NIST SP 800-53	None
OWASP Top 10 2017	All
OWASP Mobile Top 10 2016	All
ASD STIG 4.10	All
OWASP Top 10 API	All
OWASP Top 10 2010	All
ASA Mobile Premium	All
ASA Premium	All
CWE top 25	All
MOIS(KISA) Secure Coding 2021	All
OWASP ASVS	All
OWASP Top 10 2021	None
SANS top 25	All
Top Tier	All
ASD STIG 5.3	All
Base Preset	All
OWASP Top 10 API	All

2023

PCI DSS v4.0

None

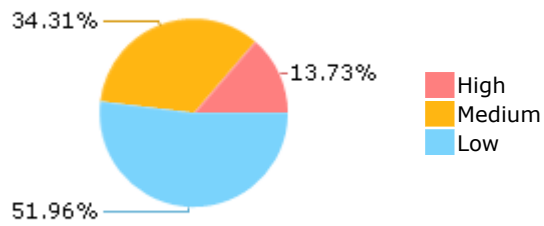
Results Limit

Results limit per query was set to 50

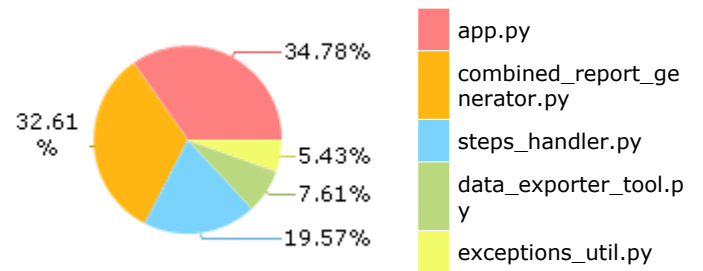
Selected Queries

Selected queries are listed in [Result Summary](#)

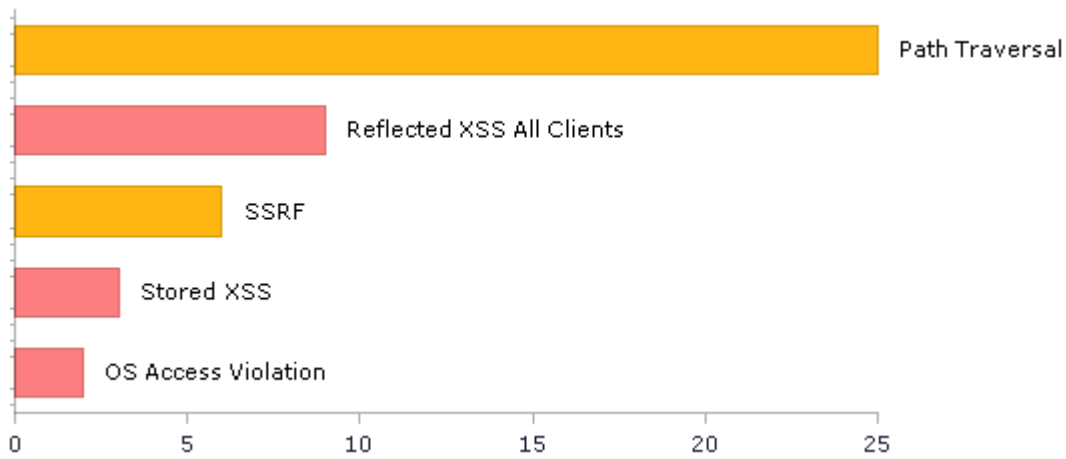
Result Summary



Most Vulnerable Files



Top 5 Vulnerabilities



Scan Summary - OWASP Top 10 2021

Category	Issues Found	Best Fix Locations
A1-Broken Access Control*	26	4
A2-Cryptographic Failures*	0	0
A3-Injection*	14	9
A4-Insecure Design*	48	24
A5-Security Misconfiguration	1	1
A6-Vulnerable and Outdated Components	0	0
A7-Identification and Authentication Failures*	4	4
A8-Software and Data Integrity Failures*	1	1
A9-Security Logging and Monitoring Failures*	0	0
A10-Server-Side Request Forgery	7	2

* Project scan results do not include all relevant queries. Presets and/or Filters should be changed to include all relevant standard queries.

Scan Summary - NIST SP 800-53

Category	Issues Found	Best Fix Locations
AC-12 Session Termination (P2)	0	0
AC-3 Access Enforcement (P1)	0	0
AC-4 Information Flow Enforcement (P1)	0	0
AC-6 Least Privilege (P1)	0	0
AU-9 Protection of Audit Information (P1)*	0	0
CM-6 Configuration Settings (P2)	0	0
IA-5 Authenticator Management (P1)	0	0
IA-6 Authenticator Feedback (P2)	0	0
IA-8 Identification and Authentication (Non-Organizational Users) (P1)	0	0
SC-12 Cryptographic Key Establishment and Management (P1)	0	0
SC-13 Cryptographic Protection (P1)	0	0
SC-17 Public Key Infrastructure Certificates (P1)	0	0
SC-18 Mobile Code (P2)	0	0
SC-23 Session Authenticity (P1)	1	1
SC-28 Protection of Information at Rest (P1)*	0	0
SC-4 Information in Shared Resources (P1)	0	0
SC-5 Denial of Service Protection (P1)	0	0
SC-8 Transmission Confidentiality and Integrity (P1)	0	0
SI-10 Information Input Validation (P1)*	6	1
SI-11 Error Handling (P2)	48	24
SI-15 Information Output Filtering (P0)*	12	8
SI-16 Memory Protection (P1)	0	0

* Project scan results do not include all relevant queries. Presets and/or Filters should be changed to include all relevant standard queries.

Scan Summary - PCI DSS v4.0

Category	Issues Found	Best Fix Locations
PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development*	94	43

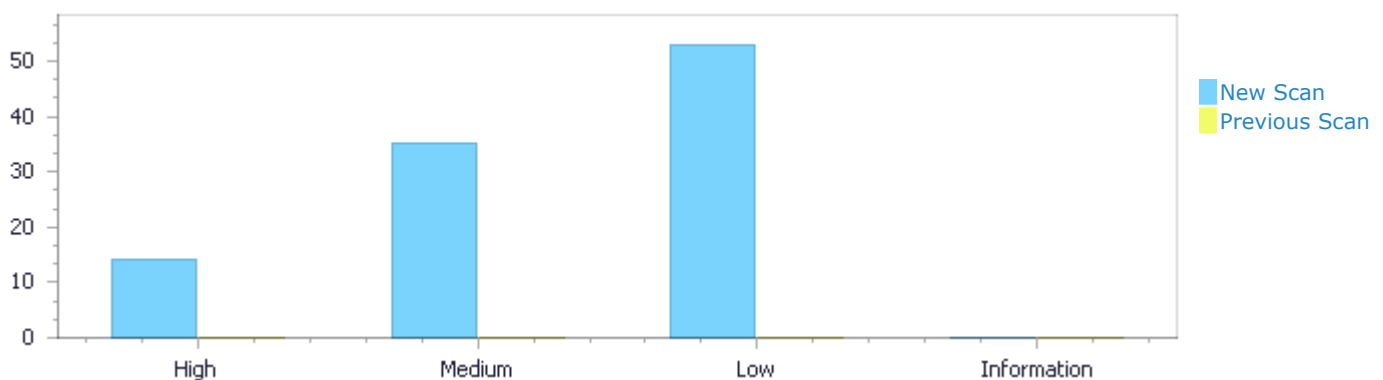
* Project scan results do not include all relevant queries. Presets and/or Filters should be changed to include all relevant standard queries.

Results Distribution By Status

First scan of the project

	High	Medium	Low	Information	Total
New Issues	14	35	53	0	102
Recurrent Issues	0	0	0	0	0
Total	14	35	53	0	102

Fixed Issues	0	0	0	0	0
--------------	---	---	---	---	---



Results Distribution By State

	High	Medium	Low	Information	Total
To Verify	14	35	53	0	102
Not Exploitable	0	0	0	0	0
Confirmed	0	0	0	0	0
Urgent	0	0	0	0	0
Proposed Not Exploitable	0	0	0	0	0
Total	14	35	53	0	102

Result Summary

Vulnerability Type	Occurrences	Severity
Reflected XSS All Clients	9	High
Stored XSS	3	High
OS Access Violation	2	High
Path Traversal	25	Medium
SSRF	6	Medium
CSRF	1	Medium
Hardcoded Password in Connection String	1	Medium

Missing HSTS Header	1	Medium
SSRF	1	Medium
Information Exposure Through an Error Message	48	Low
Missing Content Security Policy	2	Low
Improper Resource Shutdown or Release	1	Low
Missing CSP Header	1	Low
Potential Clickjacking on Legacy Browsers	1	Low

10 Most Vulnerable Files

High and Medium Vulnerabilities

File Name	Issues Found
EDS_updated_fixed/combined_report_generator.py	28
EDS_updated_fixed/app.py	19
EDS_updated_fixed/exceptions_handler.py	4
EDS_updated_fixed/exceptions_util.py	1
EDS_updated_fixed/static/api-listener.js	1
EDS_updated_fixed/data_exporter_tool.py	1

Scan Results Details

Reflected XSS All Clients

Query Path:

Python\Cx\Python High Risk\Reflected XSS All Clients Version:3

Categories

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)
 OWASP Top 10 2013: A3-Cross-Site Scripting (XSS)
 FISMA 2014: System And Information Integrity
 NIST SP 800-53: SI-15 Information Output Filtering (P0)
 OWASP Top 10 2017: A7-Cross-Site Scripting (XSS)
 ASA Premium: ASA Premium
 CWE top 25: CWE top 25
 MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
 OWASP ASVS: V05 Validation, Sanitization and Encoding
 OWASP Top 10 2021: A3-Injection
 SANS top 25: SANS top 25
 Top Tier: Top Tier
 ASD STIG 5.3: APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.
 PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Reflected XSS All Clients\Path 1:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsect5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=3
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method static_files embeds untrusted data in generated output with ReturnStmt, at line 282 of EDS_updated_fixed/app.py. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input filename, which is read by the static_files method at line 282 of EDS_updated_fixed/app.py. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	282	284
Object	filename	ReturnStmt

Code Snippet

```

File Name    EDS_updated_fixed/app.py
Method      def static_files(filename):

```

```

....
282. def static_files(filename):
....
284. return send_from_directory(STATIC_DIR, filename)

```

Reflected XSS All Clients\Path 2:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=4
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `download_file` embeds untrusted data in generated output with `ReturnStmt`, at line 744 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input filename, which is read by the `download_file` method at line 744 of `EDS_updated_fixed/app.py`. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	<code>EDS_updated_fixed/app.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	744	746
Object	filename	ReturnStmt

Code Snippet

File Name `EDS_updated_fixed/app.py`
 Method `def download_file(filename):`

```

....
744. def download_file(filename):
....
746. return send_from_directory(DOWNLOADS_DIR, filename,
as_attachment=True)

```

Reflected XSS All Clients\Path 3:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=5
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `console_tail` embeds untrusted data in generated output with `ReturnStmt`, at line 753 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input readlines, which is read by the `console_tail` method at line 753 of

EDS_updated_fixed/app.py. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	762	765
Object	readlines	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
Method def console_tail():

```
....
762. lines = f.readlines() [-limit:]
....
765. return jsonify({
```

Reflected XSS All Clients\Path 4:

Severity High
Result State To Verify
Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=6>
Status New
Detection Date 9/25/2026 4:44:32 PM

The method meta_manage_theme embeds untrusted data in generated output with ReturnStmt, at line 299 of EDS_updated_fixed/app.py. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input get_json, which is read by the meta_manage_theme method at line 299 of EDS_updated_fixed/app.py. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	301	311
Object	get_json	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_theme():

```
....
301. data = request.get_json(force=True) or {}
....
311. return jsonify({'message': 'theme added', 'name': name})
```

Reflected XSS All Clients\Path 5:

Severity High

Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=7
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `meta_manage_theme` embeds untrusted data in generated output with `ReturnStmt`, at line 299 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input `get_json`, which is read by the `meta_manage_theme` method at line 299 of `EDS_updated_fixed/app.py`. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	<code>EDS_updated_fixed/app.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	301	340
Object	<code>get_json</code>	<code>ReturnStmt</code>

Code Snippet

File Name `EDS_updated_fixed/app.py`
 Method `def meta_manage_theme():`

```
....
301. data = request.get_json(force=True) or {}
....
340. return jsonify({'message': 'theme updated', 'oldName': old_name,
'newName': new_name})
```

Reflected XSS All Clients\Path 6:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=8
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `meta_manage_theme` embeds untrusted data in generated output with `ReturnStmt`, at line 299 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input `get_json`, which is read by the `meta_manage_theme` method at line 299 of `EDS_updated_fixed/app.py`. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	<code>EDS_updated_fixed/app.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	301	368
Object	<code>get_json</code>	<code>ReturnStmt</code>

Code Snippet

File Name EDS_updated_fixed/app.py
 Method def meta_manage_theme():

```
....
301. data = request.get_json(force=True) or {}
....
368. return jsonify({'message': 'theme deleted', 'name': name})
```

Reflected XSS All Clients\Path 7:

Severity High
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=9>
 Status New
 Detection Date 9/25/2026 4:44:32 PM

The method meta_manage_subtheme embeds untrusted data in generated output with ReturnStmt, at line 376 of EDS_updated_fixed/app.py. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input get_json, which is read by the meta_manage_subtheme method at line 376 of EDS_updated_fixed/app.py. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	378	389
Object	get_json	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
 Method def meta_manage_subtheme():

```
....
378. data = request.get_json(force=True) or {}
....
389. return jsonify({'message': 'sub-theme added', 'name': name,
'parentTheme': parent})
```

Reflected XSS All Clients\Path 8:

Severity High
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=10>
 Status New
 Detection Date 9/25/2026 4:44:32 PM

The method meta_manage_subtheme embeds untrusted data in generated output with ReturnStmt, at line 376 of EDS_updated_fixed/app.py. This untrusted data is embedded into

the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input `get_json`, which is read by the `meta_manage_subtheme` method at line 376 of `EDS_updated_fixed/app.py`. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	378	445
Object	get_json	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_subtheme():

```
....
378. data = request.get_json(force=True) or {}
....
445. return jsonify({'message': 'sub-theme deleted', 'name': name})
```

Reflected XSS All Clients\Path 9:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=12
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `exceptions_collection` embeds untrusted data in generated output with `ReturnStmt`, at line 456 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by simply providing modified data in the user input `get_json`, which is read by the `exceptions_collection` method at line 456 of `EDS_updated_fixed/app.py`. This input then flows through the code straight to the output web page, without sanitization.

This can enable a Reflected Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	496	523
Object	get_json	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
Method def exceptions_collection():

```

.....
496.  data = request.get_json(force=True) or {}
.....
523.  return jsonify({'message': 'exception added', 'exception':
added}), 201

```

Stored XSS

Query Path:

Python\Cx\Python High Risk\Stored XSS Version:3

Categories

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)
 OWASP Top 10 2013: A3-Cross-Site Scripting (XSS)
 FISMA 2014: System And Information Integrity
 NIST SP 800-53: SI-15 Information Output Filtering (P0)
 OWASP Top 10 2017: A7-Cross-Site Scripting (XSS)
 ASA Premium: ASA Premium
 CWE top 25: CWE top 25
 MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
 OWASP ASVS: V05 Validation, Sanitization and Encoding
 OWASP Top 10 2021: A3-Injection
 SANS top 25: SANS top 25
 Top Tier: Top Tier
 ASD STIG 5.3: APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.
 Base Preset: Base Preset
 PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Stored XSS\Path 1:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=24
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `execution_log` embeds untrusted data in generated output with `ReturnStmt`, at line 775 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by saving malicious data in a data-store ahead of time. The attacker's modified data is then read from the database by the `get_execution_summary` method with `load`, at line 63 of `EDS_updated_fixed/exceptions_util.py`. This untrusted data then flows through the code straight to the output web page, without sanitization.

This can enable a Stored Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/exceptions_util.py	EDS_updated_fixed/app.py
Line	80	780
Object	load	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/exceptions_util.py
 Method def get_execution_summary():

```
....
80. execution_log = json.load(f)
```

File Name EDS_updated_fixed/app.py
 Method def execution_log():

```
....
780. return jsonify(summary)
```

Stored XSS\Path 2:

Severity High
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=26>
 Status New
 Detection Date 9/25/2026 4:44:32 PM

The method exceptions_collection embeds untrusted data in generated output with ReturnStmt, at line 456 of EDS_updated_fixed/app.py. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by saving malicious data in a data-store ahead of time. The attacker's modified data is then read from the database by the read_exceptions method with DictReader, at line 144 of EDS_updated_fixed/exceptions_handler.py. This untrusted data then flows through the code straight to the output web page, without sanitization.

This can enable a Stored Cross-Site Scripting (XSS) attack.

	Source	Destination
File	EDS_updated_fixed/exceptions_handler.py	EDS_updated_fixed/app.py
Line	157	487
Object	DictReader	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/exceptions_handler.py
 Method def read_exceptions(self):

```
....
157. reader = csv.DictReader(f)
```

File Name EDS_updated_fixed/app.py
 Method def exceptions_collection():

```
....
487. return jsonify({
```

Stored XSS\Path 3:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=27
Status	New
Detection Date	9/25/2026 4:44:32 PM

The method `exceptions_item` embeds untrusted data in generated output with `ReturnStmt`, at line 527 of `EDS_updated_fixed/app.py`. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page.

The attacker would be able to alter the returned web page by saving malicious data in a data-store ahead of time. The attacker's modified data is then read from the database by the `read_exceptions` method with `DictReader`, at line 144 of `EDS_updated_fixed/exceptions_handler.py`. This untrusted data then flows through the code straight to the output web page, without sanitization. This can enable a Stored Cross-Site Scripting (XSS) attack.

	Source	Destination
File	<code>EDS_updated_fixed/exceptions_handler.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	157	572
Object	<code>DictReader</code>	<code>ReturnStmt</code>

Code Snippet

File Name `EDS_updated_fixed/exceptions_handler.py`
 Method `def read_exceptions(self):`

```
....
157. reader = csv.DictReader(f)
```

File Name `EDS_updated_fixed/app.py`
 Method `def exceptions_item(ex_id):`

```
....
572. return jsonify({'message': 'updated', 'exception': updated})
```

OS Access Violation

Query Path:

Python\Cx\Python High Risk\OS Access Violation Version:3

Categories

OWASP Top 10 2017: A5-Broken Access Control

ASA Premium: ASA Premium

CWE top 25: CWE top 25

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
OWASP Top 10 2021: A3-Injection
Top Tier: Top Tier
PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

OS Access Violation\Path 1:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=1
Status	New
Detection Date	9/25/2026 4:44:32 PM

The user-provided input from argv in EDS_updated_fixed/combined_report_generator.py in line 1867 is used by the file operation branch_data_dir in EDS_updated_fixed/combined_report_generator.py in line 193 without validation.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	198
Object	argv	branch_data_dir

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_combined_exceptions(downloads_dir):

```
....
198. for bf in os.listdir(branch_data_dir):
```

OS Access Violation\Path 2:

Severity	High
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=2
Status	New
Detection Date	9/25/2026 4:44:32 PM

The user-provided input from argv in EDS_updated_fixed/combined_report_generator.py in line 1867 is used by the file operation rules_dir in EDS_updated_fixed/combined_report_generator.py in line 234 without validation.

Source	Destination
--------	-------------

File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	261
Object	argv	rules_dir

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py

Method def count_impacted_customers(downloads_dir):

```
....
261. for fname in os.listdir(rules_dir):
```

Path Traversal

Query Path:

Python\Cx\Python Medium Threat\Path Traversal Version:3

Categories

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.8 - Improper access control

OWASP Top 10 2013: A4-Insecure Direct Object References

OWASP Top 10 2017: A5-Broken Access Control

ASA Premium: ASA Premium

CWE top 25: CWE top 25

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data

OWASP ASVS: V12 Files and Resources

OWASP Top 10 2021: A1-Broken Access Control

SANS top 25: SANS top 25

Top Tier: Top Tier

Base Preset: Base Preset

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

[Description](#)**Path Traversal\Path 1:**

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=11>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of

EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_combined_exceptions at line 193 of

EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	196
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_combined_exceptions(downloads_dir):

```
....
196. if not os.path.exists(branch_data_dir):
```

Path Traversal\Path 2:

Severity Medium
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=13>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_branch_user_count at line 656 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	677
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_branch_user_count(downloads_dir, data_exporter_tool=None):

```

.....
677. if os.path.exists(cache):

```

Path Traversal\Path 3:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=14>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_branch_user_count at line 656 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	679
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_branch_user_count(downloads_dir, data_exporter_tool=None):

```

.....
679. df = pd.read_csv(cache)

```

Path Traversal\Path 4:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=15
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	406
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_exception_execution_log(downloads_dir):

```
....
406. if os.path.exists(rules_dir):
```

Path Traversal\Path 5:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=16
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

Source	Destination
--------	-------------

File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	425
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_exception_execution_log(downloads_dir):

```
....
425. if os.path.exists(branch_data_dir):
```

Path Traversal\Path 6:

Severity Medium
Result State To Verify
Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=18>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in count_impacted_customers at line 234 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	257
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def count_impacted_customers(downloads_dir):

```

.....
257. if not os.path.exists(rules_dir):

```

Path Traversal\Path 7:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=19>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	361
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```

.....
361. if os.path.exists(json_log_path):

```

Path Traversal\Path 8:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=20
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	363
Object	argv	open

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_exception_execution_log(downloads_dir):

```
....
363. with open(json_log_path, 'r') as f:
```

Path Traversal\Path 9:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=21
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

Source	Destination
--------	-------------

File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	388
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```
....
388. if os.path.exists(exc_csv):
```

Path Traversal\Path 10:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=22>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	390
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```

.....
390. df_exc = pd.read_csv(exc_csv)

```

Path Traversal\Path 11:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=25>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_combined_exceptions at line 193 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	200
Object	argv	isdir

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_combined_exceptions(downloads_dir):

```

.....
200. if not os.path.isdir(bp):

```

Path Traversal\Path 12:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=28
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	356
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_exception_execution_log(downloads_dir):

```
....
356. if os.path.exists(candidate):
```

Path Traversal\Path 13:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=29
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

Source	Destination
--------	-------------

File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	383
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_exception_execution_log(downloads_dir):

```
....
383. if os.path.exists(candidate):
```

Path Traversal\Path 14:

Severity Medium
Result State To Verify
Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=30>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	417
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```

.....
417. df_tmp = pd.read_csv(fpath)

```

Path Traversal\Path 15:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=31>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	428
Object	argv	isdir

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```

.....
428. if not os.path.isdir(bp):

```

Path Traversal\Path 16:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=32
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method `generate_combined_analytics_report` at line 1867 of `EDS_updated_fixed/combined_report_generator.py` gets dynamic data from the `argv` element. This element's value then flows through the code and is eventually used in a file path for local disk access in `count_impacted_customers` at line 234 of `EDS_updated_fixed/combined_report_generator.py`. This may cause a Path Traversal vulnerability.

	Source	Destination
File	<code>EDS_updated_fixed/combined_report_generator.py</code>	<code>EDS_updated_fixed/combined_report_generator.py</code>
Line	1867	277
Object	<code>argv</code>	<code>read_csv</code>

Code Snippet

File Name `EDS_updated_fixed/combined_report_generator.py`
 Method `generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")`

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name `EDS_updated_fixed/combined_report_generator.py`
 Method `def count_impacted_customers(downloads_dir):`

```
....
277. df = pd.read_csv(fpath)
```

Path Traversal\Path 17:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=33
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method `generate_combined_analytics_report` at line 1867 of `EDS_updated_fixed/combined_report_generator.py` gets dynamic data from the `argv` element. This element's value then flows through the code and is eventually used in a file path for local disk access in `load_combined_exceptions` at line 193 of `EDS_updated_fixed/combined_report_generator.py`. This may cause a Path Traversal vulnerability.

Source	Destination
--------	-------------

File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	203
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_combined_exceptions(downloads_dir):

```
....
203. if not os.path.exists(cp) or os.path.getsize(cp) == 0:
```

Path Traversal\Path 18:

Severity Medium
Result State To Verify
Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=34>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_combined_exceptions at line 193 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	206
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_combined_exceptions(downloads_dir):

```

.....
206. df = pd.read_csv(cp)

```

Path Traversal\Path 19:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=35>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	431
Object	argv	exists

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```

.....
431. if not os.path.exists(cp):

```

Path Traversal\Path 20:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=39
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method generate_combined_analytics_report at line 1867 of EDS_updated_fixed/combined_report_generator.py gets dynamic data from the argv element. This element's value then flows through the code and is eventually used in a file path for local disk access in load_exception_execution_log at line 338 of EDS_updated_fixed/combined_report_generator.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	434
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_exception_execution_log(downloads_dir):

```
....
434. df_br = pd.read_csv(cp)
```

Path Traversal\Path 21:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=41
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method meta_manage_theme at line 299 of EDS_updated_fixed/app.py gets dynamic data from the get_json element. This element's value then flows through the code and is eventually used in a file path for local disk access in update_sheet at line 224 of EDS_updated_fixed/app.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	301	245

Object	get_json	to_excel
--------	----------	----------

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_theme():

```
....
301. data = request.get_json(force=True) or {}
```

File Name EDS_updated_fixed/app.py
Method def update_sheet(sheet, data):

```
....
245. df.to_excel(writer, sheet_name=sheet, index=False)
```

Path Traversal\Path 22:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=43
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method meta_manage_subtheme at line 376 of EDS_updated_fixed/app.py gets dynamic data from the get_json element. This element's value then flows through the code and is eventually used in a file path for local disk access in update_sheet at line 224 of EDS_updated_fixed/app.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	378	245
Object	get_json	to_excel

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_subtheme():

```
....
378. data = request.get_json(force=True) or {}
```

File Name EDS_updated_fixed/app.py
Method def update_sheet(sheet, data):

```
....
245. df.to_excel(writer, sheet_name=sheet, index=False)
```

Path Traversal\Path 23:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=45
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method meta_manage_theme at line 299 of EDS_updated_fixed/app.py gets dynamic data from the get_json element. This element's value then flows through the code and is eventually used in a file path for local disk access in append_unique at line 185 of EDS_updated_fixed/app.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	301	219
Object	get_json	to_excel

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_theme():

```
....
301. data = request.get_json(force=True) or {}
```

File Name EDS_updated_fixed/app.py
Method def append_unique(sheet, row):

```
....
219. df.to_excel(writer, sheet_name=sheet, index=False)
```

Path Traversal\Path 24:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=47
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method meta_manage_subtheme at line 376 of EDS_updated_fixed/app.py gets dynamic data from the get_json element. This element's value then flows through the code and is eventually used in a file path for local disk access in append_unique at line 185 of EDS_updated_fixed/app.py. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	378	219
Object	get_json	to_excel

Code Snippet

File Name EDS_updated_fixed/app.py

Method `def meta_manage_subtheme():`

```
....
378. data = request.get_json(force=True) or {}
```

File Name EDS_updated_fixed/app.py

Method `def append_unique(sheet, row):`

```
....
219. df.to_excel(writer, sheet_name=sheet, index=False)
```

Path Traversal\Path 25:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=48>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method `exceptions_collection` at line 456 of `EDS_updated_fixed/app.py` gets dynamic data from the `get_json` element. This element's value then flows through the code and is eventually used in a file path for local disk access in `append_unique` at line 185 of `EDS_updated_fixed/app.py`. This may cause a Path Traversal vulnerability.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	496	219
Object	get_json	to_excel

Code Snippet

File Name EDS_updated_fixed/app.py

Method `def exceptions_collection():`

```
....
496. data = request.get_json(force=True) or {}
```

File Name EDS_updated_fixed/app.py

Method `def append_unique(sheet, row):`

```
....
219. df.to_excel(writer, sheet_name=sheet, index=False)
```

SSRF

Query Path:

Python\Cx\Python Medium Threat\SSRF Version:3

Categories

FISMA 2014: System And Information Integrity

NIST SP 800-53: SI-10 Information Input Validation (P1)
 OWASP Top 10 2017: A5-Broken Access Control
 ASA Premium: ASA Premium
 CWE top 25: CWE top 25
 MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
 OWASP ASVS: V05 Validation, Sanitization and Encoding
 OWASP Top 10 2021: A10-Server-Side Request Forgery
 OWASP Top 10 API 2023: API7-Server Side Request Forgery

Description

SSRF\Path 1:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=97
Status	New
Detection Date	9/25/2026 4:44:32 PM

The application sends a request to a remote server, for some resource, using read_csv in EDS_updated_fixed/combined_report_generator.py:656. However, an attacker can control the target of the request, by sending a URL or other data in argv at EDS_updated_fixed/combined_report_generator.py:1867.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	679
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_branch_user_count(downloads_dir, data_exporter_tool=None):

```
....
679. df = pd.read_csv(cache)
```

SSRF\Path 2:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=98
Status	New
Detection Date	9/25/2026 4:44:32 PM

The application sends a request to a remote server, for some resource, using read_csv in EDS_updated_fixed/combined_report_generator.py:338. However, an attacker can control the target of the request, by sending a URL or other data in argv at EDS_updated_fixed/combined_report_generator.py:1867.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	390
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_exception_execution_log(downloads_dir):

```
....
390. df_exc = pd.read_csv(exc_csv)
```

SSRF\Path 3:

Severity Medium
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=99>
 Status New
 Detection Date 9/25/2026 4:44:32 PM

The application sends a request to a remote server, for some resource, using read_csv in EDS_updated_fixed/combined_report_generator.py:338. However, an attacker can control the target of the request, by sending a URL or other data in argv at EDS_updated_fixed/combined_report_generator.py:1867.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	417
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def load_exception_execution_log(downloads_dir):

```

.....
417. df_tmp = pd.read_csv(fpath)

```

SSRF\Path 4:

Severity Medium

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=100>

Status New

Detection Date 9/25/2026 4:44:32 PM

The application sends a request to a remote server, for some resource, using read_csv in EDS_updated_fixed/combined_report_generator.py:234. However, an attacker can control the target of the request, by sending a URL or other data in argv at EDS_updated_fixed/combined_report_generator.py:1867.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	277
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```

.....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")

```

File Name EDS_updated_fixed/combined_report_generator.py

Method def count_impacted_customers(downloads_dir):

```

.....
277. df = pd.read_csv(fpath)

```

SSRF\Path 5:

Severity Medium

Result State To Verify

Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=101
Status	New
Detection Date	9/25/2026 4:44:32 PM

The application sends a request to a remote server, for some resource, using read_csv in EDS_updated_fixed/combined_report_generator.py:193. However, an attacker can control the target of the request, by sending a URL or other data in argv at EDS_updated_fixed/combined_report_generator.py:1867.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	206
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....  
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >  
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_combined_exceptions(downloads_dir):

```
....  
206. df = pd.read_csv(cp)
```

SSRF\Path 6:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=102
Status	New
Detection Date	9/25/2026 4:44:32 PM

The application sends a request to a remote server, for some resource, using read_csv in EDS_updated_fixed/combined_report_generator.py:338. However, an attacker can control the target of the request, by sending a URL or other data in argv at EDS_updated_fixed/combined_report_generator.py:1867.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	1867	434
Object	argv	read_csv

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
 Method generate_combined_analytics_report(sys.argv[1] if len(sys.argv) > 1 else "downloads")

```
....
1867. generate_combined_analytics_report(sys.argv[1] if len(sys.argv) >
1 else "downloads")
```

File Name EDS_updated_fixed/combined_report_generator.py
 Method def load_exception_execution_log(downloads_dir):

```
....
434. df_br = pd.read_csv(cp)
```

CSRF

Query Path:

Python\Cx\Python Medium Threat\CSRF Version:3

Categories

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.9 - Cross-site request forgery
 OWASP Top 10 2013: A8-Cross-Site Request Forgery (CSRF)
 NIST SP 800-53: SC-23 Session Authenticity (P1)
 ASA Premium: ASA Premium
 CWE top 25: CWE top 25
 MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
 OWASP ASVS: V13 API and Web Service
 OWASP Top 10 2021: A1-Broken Access Control
 SANS top 25: SANS top 25
 ASD STIG 5.3: APSC-DV-002500 - CAT II The application must protect from Cross-Site Request Forgery (CSRF) vulnerabilities.
 PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description**CSRF\Path 1:**

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=17
Status	New
Detection Date	9/25/2026 4:44:32 PM

Method exceptions_collection at line 456 of EDS_updated_fixed/app.py gets a parameter from a user request from exceptions_collection. This parameter value flows through the code and is eventually used to access application state altering functionality. This may enable Cross-Site Request Forgery (CSRF).

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	456	456
Object	exceptions_collection	exceptions_collection

Code Snippet

File Name EDS_updated_fixed/app.py
 Method def exceptions_collection():

```
....
456. def exceptions_collection():
```

SSRF

Query Path:

JavaScript\Cx\JavaScript Server Side Vulnerabilities\SSRF Version:1

Categories

ASA Premium: ASA Premium

CWE top 25: CWE top 25

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data

OWASP ASVS: V05 Validation, Sanitization and Encoding

OWASP Top 10 2021: A10-Server-Side Request Forgery

OWASP Top 10 API 2023: API7-Server Side Request Forgery

Description**SSRF\Path 1:**

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=23
Status	New
Detection Date	9/25/2026 4:44:33 PM

The application sends a request to a remote server, for some resource, using BinaryExpr in EDS_updated_fixed/static/api-listener.js:71. However, an attacker can control the target of the request, by sending a URL or other data in r at EDS_updated_fixed/static/api-listener.js:33.

	Source	Destination
File	EDS_updated_fixed/static/api-listener.js	EDS_updated_fixed/static/api-listener.js
Line	35	73
Object	r	BinaryExpr

Code Snippet

File Name EDS_updated_fixed/static/api-listener.js
 Method async function startExecution(ids,steps,params={}){

```
....
35. const r = await fetch(`${API_BASE_URL}/execute`,{
```

File Name EDS_updated_fixed/static/api-listener.js

Method const timer = setInterval(async()=>{

```
....
73. const r = await fetch(`${API_BASE_URL}/execution/${id}/status`);
```

Missing HSTS Header

Query Path:

Python\Cx\Python Medium Threat\Missing HSTS Header Version:3

Categories

ASA Premium: ASA Premium

OWASP ASVS: V14 Configuration

OWASP Top 10 2021: A7-Identification and Authentication Failures

OWASP Top 10 API 2023: API8-Security Misconfiguration

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Missing HSTS Header\Path 1:

Severity	Medium
Result State	To Verify
Online Results	https://pkhblc5appsect5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=37
Status	New
Detection Date	9/25/2026 4:44:32 PM

The web-application does not define an HSTS header, leaving it vulnerable to attack.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	254	254
Object	app	app

Code Snippet

File Name EDS_updated_fixed/app.py
Method app = Flask(__name__, static_folder=STATIC_DIR)

```
....
254. app = Flask(__name__, static_folder=STATIC_DIR)
```

Hardcoded Password in Connection String

Query Path:

Python\Cx\Python Medium Threat\Hardcoded Password in Connection String Version:3

Categories

PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.3 - Insecure cryptographic storage

OWASP Top 10 2013: A5-Security Misconfiguration

OWASP Top 10 2017: A6-Security Misconfiguration

ASA Premium: ASA Premium

OWASP Top 10 2021: A5-Security Misconfiguration

ASD STIG 5.3: APSC-DV-003110 - CAT I The application must not contain embedded authentication data.

OWASP Top 10 API 2023: API2-Broken Authentication

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Hardcoded Password in Connection String\Path 1:

Severity	Medium
Result State	To Verify

Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=55
Status	New
Detection Date	9/25/2026 4:44:32 PM

The application contains hardcoded connection details, ";PWD=", at line 511 of EDS_updated_fixed/data_exporter_tool.py. This connection string contains a hardcoded password, which is used in construct_and_execute_query at line 511 of EDS_updated_fixed/data_exporter_tool.py to connect to a database server with connect. This can expose the database password, and impede proper password management.

	Source	Destination
File	EDS_updated_fixed/data_exporter_tool.py	EDS_updated_fixed/data_exporter_tool.py
Line	542	542
Object	";PWD="	connect

Code Snippet

File Name EDS_updated_fixed/data_exporter_tool.py
 Method def construct_and_execute_query(columns, table_name, database_name, conditions, dsn, user, password):

```
....
542. connection = db.connect(f'DSN={dsn};UID={user};PWD={password}')
```

Information Exposure Through an Error Message

Query Path:

Python\Cx\Python Low Visibility\Information Exposure Through an Error Message Version:2

Categories

OWASP Top 10 2013: A5-Security Misconfiguration
 FISMA 2014: Configuration Management
 NIST SP 800-53: SI-11 Error Handling (P2)
 OWASP Top 10 2017: A6-Security Misconfiguration
 CWE top 25: CWE top 25
 MOIS(KISA) Secure Coding 2021: MOIS(KISA) Error processing
 OWASP ASVS: V14 Configuration
 OWASP Top 10 2021: A4-Insecure Design
 SANS top 25: SANS top 25
 ASD STIG 5.3: APSC-DV-002570 - CAT II The application must generate error messages that provide information necessary for corrective actions without revealing information that could be exploited by adversaries.
 OWASP Top 10 API 2023: API8-Security Misconfiguration
 PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Information Exposure Through an Error Message\Path 1:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=36
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method `format_excel`, at line 10 of `EDS_updated_fixed/excel_util.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `format_excel` of `EDS_updated_fixed/excel_util.py`, line 10.

	Source	Destination
File	<code>EDS_updated_fixed/excel_util.py</code>	<code>EDS_updated_fixed/excel_util.py</code>
Line	19	20
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/excel_util.py`
 Method `def format_excel(file_path, exception_column_name):`

```
....
19. except Exception as e:
20.     print(f"[WARN] Could not read {file_path}: {e} - skipping")
```

Information Exposure Through an Error Message\Path 2:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=38>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method `read_csv`, at line 36 of `EDS_updated_fixed/docx_util.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `read_csv` of `EDS_updated_fixed/docx_util.py`, line 36.

	Source	Destination
File	<code>EDS_updated_fixed/docx_util.py</code>	<code>EDS_updated_fixed/docx_util.py</code>
Line	40	41
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/docx_util.py`
 Method `def read_csv(file_path):`

```
....
40. except Exception as e:
41.     print(f"An error occurred: {e}")
```

Information Exposure Through an Error Message\Path 3:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=40>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method change_font_in_docx, at line 52 of EDS_updated_fixed/docx_util.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method change_font_in_docx of EDS_updated_fixed/docx_util.py, line 52.

	Source	Destination
File	EDS_updated_fixed/docx_util.py	EDS_updated_fixed/docx_util.py
Line	63	64
Object	e	print

Code Snippet

File Name EDS_updated_fixed/docx_util.py
Method def change_font_in_docx(doc_path):

```
....
63. except Exception as e:
64.     print(f"Error opening document: {e}")
```

Information Exposure Through an Error Message\Path 4:

Severity Low
Result State To Verify
Online Results <https://pkhblc5appsect5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=42>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method change_font_in_docx, at line 52 of EDS_updated_fixed/docx_util.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method change_font_in_docx of EDS_updated_fixed/docx_util.py, line 52.

	Source	Destination
File	EDS_updated_fixed/docx_util.py	EDS_updated_fixed/docx_util.py
Line	81	83
Object	e	print

Code Snippet

File Name EDS_updated_fixed/docx_util.py
Method def change_font_in_docx(doc_path):

```
....
81. except Exception as e:
....
83.     print(f"Skipping cell due to vertically merged cells: {e}")
```

Information Exposure Through an Error Message\Path 5:

Severity Low
Result State To Verify
Online Results <https://pkhblc5appsect5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=44>
Status New

Detection Date 9/25/2026 4:44:33 PM

Method change_font_in_docx, at line 52 of EDS_updated_fixed/docx_util.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method change_font_in_docx of EDS_updated_fixed/docx_util.py, line 52.

	Source	Destination
File	EDS_updated_fixed/docx_util.py	EDS_updated_fixed/docx_util.py
Line	81	85
Object	e	print

Code Snippet

File Name EDS_updated_fixed/docx_util.py

Method def change_font_in_docx(doc_path):

```
....
81. except Exception as e:
....
85. print(f"Error processing cell: {e}")
```

Information Exposure Through an Error Message\Path 6:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=46>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method change_font_in_docx, at line 52 of EDS_updated_fixed/docx_util.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method change_font_in_docx of EDS_updated_fixed/docx_util.py, line 52.

	Source	Destination
File	EDS_updated_fixed/docx_util.py	EDS_updated_fixed/docx_util.py
Line	86	87
Object	e	print

Code Snippet

File Name EDS_updated_fixed/docx_util.py

Method def change_font_in_docx(doc_path):

```
....
86. except Exception as e:
87. print(f"Error processing cell: {e} thus ignoring tables with merged
cells issue")
```

Information Exposure Through an Error Message\Path 7:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=46>

[objectid=199&pathid=49](#)

Status New

Detection Date 9/25/2026 4:44:33 PM

Method read_csv, at line 112 of EDS_updated_fixed/exceptions_util.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method read_csv of EDS_updated_fixed/exceptions_util.py, line 112.

	Source	Destination
File	EDS_updated_fixed/exceptions_util.py	EDS_updated_fixed/exceptions_util.py
Line	116	117
Object	e	print

Code Snippet

File Name EDS_updated_fixed/exceptions_util.py

Method def read_csv(file_path):

```
....  
116. except Exception as e:  
117.     print(f"An error occurred: {e}")
```

Information Exposure Through an Error Message\Path 8:

Severity Low

Result State To Verify

Online Results [https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&pr
objectid=199&pathid=50](https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&pr
objectid=199&pathid=50)

Status New

Detection Date 9/25/2026 4:44:33 PM

Method _generate_via_gateway, at line 80 of EDS_updated_fixed/cohere_r7b.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method _generate_via_gateway of EDS_updated_fixed/cohere_r7b.py, line 80.

	Source	Destination
File	EDS_updated_fixed/cohere_r7b.py	EDS_updated_fixed/cohere_r7b.py
Line	121	122
Object	e	print

Code Snippet

File Name EDS_updated_fixed/cohere_r7b.py

Method def _generate_via_gateway(prompt: str, max_tokens: int = 4096) -> str:

```
....  
121. except json.JSONDecodeError as e:  
122.     print(f"JSON decode error: {e}")
```

Information Exposure Through an Error Message\Path 9:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&pr>

[objectid=199&pathid=51](#)

Status New
 Detection Date 9/25/2026 4:44:33 PM

Method `_generate_via_gateway`, at line 80 of `EDS_updated_fixed/cohere_r7b.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `_generate_via_gateway` of `EDS_updated_fixed/cohere_r7b.py`, line 80.

	Source	Destination
File	<code>EDS_updated_fixed/cohere_r7b.py</code>	<code>EDS_updated_fixed/cohere_r7b.py</code>
Line	125	126
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/cohere_r7b.py`
 Method `def _generate_via_gateway(prompt: str, max_tokens: int = 4096) -> str:`

```

.....
125. except requests.RequestException as e:
126.     print(f"Request error: {e}")

```

Information Exposure Through an Error Message\Path 10:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&pr objectid=199&pathid=52>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method `meta_manage_theme`, at line 299 of `EDS_updated_fixed/app.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `meta_manage_theme` of `EDS_updated_fixed/app.py`, line 299.

	Source	Destination
File	<code>EDS_updated_fixed/app.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	344	345
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/app.py`
 Method `def meta_manage_theme():`

```

.....
344. except Exception as e:
345.     print(f"[ERROR] Failed to update theme: {e}")

```

Information Exposure Through an Error Message\Path 11:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&pr>

[objectid=199&pathid=53](#)

Status New
Detection Date 9/25/2026 4:44:33 PM

Method meta_manage_theme, at line 299 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method meta_manage_theme of EDS_updated_fixed/app.py, line 299.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	370	371
Object	e	print

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_theme():

```
....  
370. except Exception as e:  
371. print(f"[ERROR] Failed to delete theme: {e}")
```

Information Exposure Through an Error Message\Path 12:

Severity Low
Result State To Verify
Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=54>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method load_exception_execution_log, at line 338 of EDS_updated_fixed/combined_report_generator.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method load_exception_execution_log of EDS_updated_fixed/combined_report_generator.py, line 338.

	Source	Destination
File	EDS_updated_fixed/combined_report_generator.py	EDS_updated_fixed/combined_report_generator.py
Line	375	376
Object	e	print

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py
Method def load_exception_execution_log(downloads_dir):

```
....  
375. except Exception as e:  
376. print(f"[WARN] Could not load JSON execution log: {e}")
```

Information Exposure Through an Error Message\Path 13:

Severity Low

Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=56
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method meta_manage_subtheme, at line 376 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method meta_manage_subtheme of EDS_updated_fixed/app.py, line 376.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	425	426
Object	e	print

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_subtheme():

```
....  
425. except Exception as e:  
426. print(f"[ERROR] Failed to update sub-theme: {e}")
```

Information Exposure Through an Error Message\Path 14:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=57
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method meta_manage_subtheme, at line 376 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method meta_manage_subtheme of EDS_updated_fixed/app.py, line 376.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	447	448
Object	e	print

Code Snippet

File Name EDS_updated_fixed/app.py
Method def meta_manage_subtheme():

```
....  
447. except Exception as e:  
448. print(f"[ERROR] Failed to delete sub-theme: {e}")
```

Information Exposure Through an Error Message\Path 15:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=58
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method execution_worker, at line 621 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method execution_worker of EDS_updated_fixed/app.py, line 621.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	664	670
Object	e	print

Code Snippet

File Name EDS_updated_fixed/app.py

Method def execution_worker(exec_id, exception_ids, steps, params):

```
....
664. except Exception as e:
....
670. print(f"[ERROR] Execution {exec_id} failed: {e}")
```

Information Exposure Through an Error Message\Path 16:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=59
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method connect_to_dl, at line 57 of EDS_updated_fixed/data_exporter_tool.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method connect_to_dl of EDS_updated_fixed/data_exporter_tool.py, line 57.

	Source	Destination
File	EDS_updated_fixed/data_exporter_tool.py	EDS_updated_fixed/data_exporter_tool.py
Line	66	67
Object	e	print

Code Snippet

File Name EDS_updated_fixed/data_exporter_tool.py

Method def connect_to_dl(credential_variables):

```
....
66. except Exception as e:
67. print("An error occurred:", str(e))
```

Information Exposure Through an Error Message\Path 17:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=60
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method table_dropper, at line 151 of EDS_updated_fixed/data_exporter_tool.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method table_dropper of EDS_updated_fixed/data_exporter_tool.py, line 151.

	Source	Destination
File	EDS_updated_fixed/data_exporter_tool.py	EDS_updated_fixed/data_exporter_tool.py
Line	172	173
Object	e	print

Code Snippet

File Name EDS_updated_fixed/data_exporter_tool.py
 Method def table_dropper(database_name, table_name):

```
....
172. except Exception as e:
173.     print(f"An error occurred while dropping the table: {str(e)}")
```

Information Exposure Through an Error Message\Path 18:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=61
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method table_creator, at line 183 of EDS_updated_fixed/data_exporter_tool.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method table_creator of EDS_updated_fixed/data_exporter_tool.py, line 183.

	Source	Destination
File	EDS_updated_fixed/data_exporter_tool.py	EDS_updated_fixed/data_exporter_tool.py
Line	205	206
Object	e	print

Code Snippet

File Name EDS_updated_fixed/data_exporter_tool.py
 Method def table_creator(query, database_name, table_name):

```
....
205. except Exception as e:
206. print(f"An error occurred while creating the table: {str(e)}")
```

Information Exposure Through an Error Message\Path 19:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=62
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method `extract_with_checkpoints`, at line 216 of `EDS_updated_fixed/data_exporter_tool.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `extract_with_checkpoints` of `EDS_updated_fixed/data_exporter_tool.py`, line 216.

	Source	Destination
File	<code>EDS_updated_fixed/data_exporter_tool.py</code>	<code>EDS_updated_fixed/data_exporter_tool.py</code>
Line	291	292
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/data_exporter_tool.py`
Method `def extract_with_checkpoints(table_name, database_name, output_file, directory_name):`

```
....
291. except Exception as e:
292. print(f"An error occurred during data extraction: {str(e)}")
```

Information Exposure Through an Error Message\Path 20:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=63
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method `count_impacted_customers`, at line 234 of `EDS_updated_fixed/combined_report_generator.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `count_impacted_customers` of `EDS_updated_fixed/combined_report_generator.py`, line 234.

	Source	Destination
File	<code>EDS_updated_fixed/combined_report_generator.py</code>	<code>EDS_updated_fixed/combined_report_generator.py</code>
Line	303	304

Object	e	print
--------	---	-------

Code Snippet

File Name EDS_updated_fixed/combined_report_generator.py

Method def count_impacted_customers(downloads_dir):

```

....
303. except Exception as e:
304. print(f"[ERROR] Failed to count customers for {exception_name}:
{str(e)}")

```

Information Exposure Through an Error Message\Path 21:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=64>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method extract_with_threads, at line 598 of EDS_updated_fixed/data_exporter_tool.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method extract_with_threads of EDS_updated_fixed/data_exporter_tool.py, line 598.

	Source	Destination
File	EDS_updated_fixed/data_exporter_tool.py	EDS_updated_fixed/data_exporter_tool.py
Line	740	741
Object	e	print

Code Snippet

File Name EDS_updated_fixed/data_exporter_tool.py

Method def extract_with_threads(table_name, database_name, output_file, directory_name, num_threads):

```

....
740. except Exception as e:
741. print(f"An error occurred: {str(e)}")

```

Information Exposure Through an Error Message\Path 22:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=65>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method execute_step_5, at line 695 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error format_exc. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	767	24
Object	format_exc	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def execute_step_5(ctx: Dict[str, Any]) -> None:

```
.....
767.  log(f"[DEBUG] Traceback: {traceback.format_exc()}")
```

File Name EDS_updated_fixed/steps_handler.py
Method def log(message: str) -> None:

```
.....
24.  print(message)
```

Information Exposure Through an Error Message\Path 23:

Severity Low
Result State To Verify
Online Results <https://pkhblc5appsect5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=66>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method execute_step_5, at line 695 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error format_exc. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	779	24
Object	format_exc	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def execute_step_5(ctx: Dict[str, Any]) -> None:

```
.....
779.  log(f"[DEBUG] Traceback: {traceback.format_exc()}")
```

File Name EDS_updated_fixed/steps_handler.py
Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 24:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=67
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method execute_step_1, at line 71 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	146	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def execute_step_1(ctx: Dict[str, Any]) -> None:

```
....
146. except Exception as e:
```

File Name EDS_updated_fixed/steps_handler.py
Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 25:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=68
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method process_exception, at line 153 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error exc. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	158	24

Object	exc	print
--------	-----	-------

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method def process_exception(query: str, exception_name: str, db_name: str, downloads_dir: str) -> None:

```
....
158. except Exception as exc: log(f"[WARN] Drop skipped for
{db_name}.{table_name}: {exc}")
```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 26:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=69>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method execute_step_3, at line 179 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error grouped_error. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	218	24
Object	grouped_error	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method def execute_step_3(ctx: Dict[str, Any]) -> None:

```
....
218. except Exception as grouped_error:
```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 27:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=71
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method execute_step_3, at line 179 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error exc. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	262	24
Object	exc	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def execute_step_3(ctx: Dict[str, Any]) -> None:

```
....  
262. except Exception as exc: log(f"[WARN] AI summary skipped for  
{row['exception_name']}: {exc}")
```

File Name EDS_updated_fixed/steps_handler.py
Method def log(message: str) -> None:

```
....  
24. print(message)
```

Information Exposure Through an Error Message\Path 28:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=72
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	296	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method def prepare_final_exceptions_report(exceptions_file_path: str, branch_info_path: str,

```

.....
296.     except Exception as e:

```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```

.....
24.     print(message)

```

Information Exposure Through an Error Message\Path 29:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=73>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	302	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method def prepare_final_exceptions_report(exceptions_file_path: str, branch_info_path: str,

```

.....
302.     except Exception as e:

```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```

.....
24.     print(message)

```

Information Exposure Through an Error Message\Path 30:

Severity Low

Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=74
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	374	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def prepare_final_exceptions_report(exception_file_path: str, branch_info_path: str,

```
....  
374. except Exception as e:
```

File Name EDS_updated_fixed/steps_handler.py
Method def log(message: str) -> None:

```
....  
24. print(message)
```

Information Exposure Through an Error Message\Path 31:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=75
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	417	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method	def prepare_final_exceptions_report(exceptions_file_path: str, branch_info_path: str,
	<pre> 417. except Exception as e: </pre>
File Name	EDS_updated_fixed/steps_handler.py
Method	def log(message: str) -> None:
	<pre> 24. print(message) </pre>

Information Exposure Through an Error Message\Path 32:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=76
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	499	24
Object	e	print

Code Snippet

File Name	EDS_updated_fixed/steps_handler.py
Method	def prepare_final_exceptions_report(exceptions_file_path: str, branch_info_path: str,
	<pre> 499. except Exception as e: </pre>
File Name	EDS_updated_fixed/steps_handler.py
Method	def log(message: str) -> None:
	<pre> 24. print(message) </pre>

Information Exposure Through an Error Message\Path 33:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=76

[objectid=199&pathid=77](#)

Status New
Detection Date 9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	557	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def prepare_final_exceptions_report(exception_file_path: str, branch_info_path: str,

```
....
557. except Exception as e:
```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 34:

Severity Low
Result State To Verify
Online Results <https://pkhblc5appsect5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=78>
Status New
Detection Date 9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 278 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	625	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
Method def prepare_final_exceptions_report(exception_file_path: str, branch_info_path: str,

```
....
625. except Exception as e:
```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 35:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=79>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method formattize_branch_data_basic, at line 644 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	685	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method def formattize_branch_data_basic(branch_data_dir: str) -> None:

```
....
685. except Exception as e:
```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 36:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=80>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method `execute_step_5`, at line 695 of `EDS_updated_fixed/steps_handler.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `log` of `EDS_updated_fixed/steps_handler.py`, line 22.

	Source	Destination
File	<code>EDS_updated_fixed/steps_handler.py</code>	<code>EDS_updated_fixed/steps_handler.py</code>
Line	764	24
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/steps_handler.py`
 Method `def execute_step_5(ctx: Dict[str, Any]) -> None:`

```
.....
764.     except Exception as e:
```

File Name `EDS_updated_fixed/steps_handler.py`
 Method `def log(message: str) -> None:`

```
.....
24.     print(message)
```

Information Exposure Through an Error Message\Path 37:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=83>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method `execute_step_5`, at line 695 of `EDS_updated_fixed/steps_handler.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to print, in method `log` of `EDS_updated_fixed/steps_handler.py`, line 22.

	Source	Destination
File	<code>EDS_updated_fixed/steps_handler.py</code>	<code>EDS_updated_fixed/steps_handler.py</code>
Line	776	24
Object	<code>e</code>	<code>print</code>

Code Snippet

File Name `EDS_updated_fixed/steps_handler.py`
 Method `def execute_step_5(ctx: Dict[str, Any]) -> None:`

```
.....
776.     except Exception as e:
```

File Name `EDS_updated_fixed/steps_handler.py`

Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 38:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=84>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method create_zip_archive, at line 937 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py
Line	993	24
Object	e	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py
 Method def create_zip_archive(downloads_dir: str) -> None:

```
....
993. except Exception as e:
```

File Name EDS_updated_fixed/steps_handler.py
 Method def log(message: str) -> None:

```
....
24. print(message)
```

Information Exposure Through an Error Message\Path 39:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=85>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method execute_step_6, at line 1007 of EDS_updated_fixed/steps_handler.py, handles an Exception or runtime Error exc. During the exception handling code, the application exposes the exception details to print, in method log of EDS_updated_fixed/steps_handler.py, line 22.

	Source	Destination
File	EDS_updated_fixed/steps_handler.py	EDS_updated_fixed/steps_handler.py

Line	1014	24
Object	exc	print

Code Snippet

File Name EDS_updated_fixed/steps_handler.py

Method def execute_step_6(ctx: Dict[str, Any]) -> None:

```

.....
1014. except ImportError as exc:

```

File Name EDS_updated_fixed/steps_handler.py

Method def log(message: str) -> None:

```

.....
24. print(message)

```

Information Exposure Through an Error Message\Path 40:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=86>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method prepare_final_exceptions_report, at line 132 of EDS_updated_fixed/exceptions_util.py, handles an Exception or runtime Error exc. During the exception handling code, the application exposes the exception details to print, in method print_log of EDS_updated_fixed/exceptions_util.py, line 107.

	Source	Destination
File	EDS_updated_fixed/exceptions_util.py	EDS_updated_fixed/exceptions_util.py
Line	150	108
Object	exc	print

Code Snippet

File Name EDS_updated_fixed/exceptions_util.py

Method def prepare_final_exceptions_report(exceptions_file_path, branch_info_path, cohere_api_key, logger):

```

.....
150. except Exception as exc: print_log(f"[WARN] AI summary skipped:
{exc}", logger)

```

File Name EDS_updated_fixed/exceptions_util.py

Method def print_log(text, logger):

```
....
108. print('---',text,'---')
```

Information Exposure Through an Error Message\Path 41:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=87
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method rule_based_exception_identification, at line 165 of EDS_updated_fixed/exceptions_util.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to print, in method print_log of EDS_updated_fixed/exceptions_util.py, line 107.

	Source	Destination
File	EDS_updated_fixed/exceptions_util.py	EDS_updated_fixed/exceptions_util.py
Line	178	108
Object	e	print

Code Snippet

File Name EDS_updated_fixed/exceptions_util.py
 Method def rule_based_exception_identification(exceptions_csv, logger=None, verbose=True):

```
....
178. except Exception as e:
```

File Name EDS_updated_fixed/exceptions_util.py
 Method def print_log(text,logger):

```
....
108. print('---',text,'---')
```

Information Exposure Through an Error Message\Path 42:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=88
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method prepare_exceptions_data, at line 215 of EDS_updated_fixed/exceptions_util.py, handles an Exception or runtime Error exc. During the exception handling code, the application exposes the exception details to print, in method print_log of EDS_updated_fixed/exceptions_util.py, line 107.

Source	Destination
--------	-------------

File	EDS_updated_fixed/exceptions_util.py	EDS_updated_fixed/exceptions_util.py
Line	220	108
Object	exc	print

Code Snippet

File Name EDS_updated_fixed/exceptions_util.py

Method def prepare_exceptions_data(sql_text, exception_name, logger):

```
....
220. except Exception as exc: print_log(f"[WARN] Drop skipped:
{exc}", logger)
```

File Name EDS_updated_fixed/exceptions_util.py

Method def print_log(text, logger):

```
....
108. print('---', text, '---')
```

Information Exposure Through an Error Message\Path 43:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=89>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method meta_manage_theme, at line 299 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to ReturnStmt, in method meta_manage_theme of EDS_updated_fixed/app.py, line 299.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	344	346
Object	e	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py

Method def meta_manage_theme():

```
....
344. except Exception as e:
....
346. return jsonify({'error': str(e)}), 500
```

Information Exposure Through an Error Message\Path 44:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=90>

Status New
 Detection Date 9/25/2026 4:44:33 PM

Method meta_manage_theme, at line 299 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to ReturnStmt, in method meta_manage_theme of EDS_updated_fixed/app.py, line 299.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	370	372
Object	e	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
 Method def meta_manage_theme():

```
....
370. except Exception as e:
....
372. return jsonify({'error': str(e)}), 500
```

Information Exposure Through an Error Message\Path 45:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=91>
 Status New
 Detection Date 9/25/2026 4:44:33 PM

Method meta_manage_subtheme, at line 376 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to ReturnStmt, in method meta_manage_subtheme of EDS_updated_fixed/app.py, line 376.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	425	427
Object	e	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py
 Method def meta_manage_subtheme():

```
....
425. except Exception as e:
....
427. return jsonify({'error': str(e)}), 500
```

Information Exposure Through an Error Message\Path 46:

Severity Low
 Result State To Verify
 Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=91>

[objectid=199&pathid=92](#)

Status New

Detection Date 9/25/2026 4:44:33 PM

Method meta_manage_subtheme, at line 376 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to ReturnStmt, in method meta_manage_subtheme of EDS_updated_fixed/app.py, line 376.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	447	449
Object	e	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py

Method def meta_manage_subtheme():

```

....
447.     except Exception as e:
....
449.     return jsonify({'error': str(e)}), 500

```

Information Exposure Through an Error Message\Path 47:

Severity Low

Result State To Verify

Online Results <https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&pr objectid=199&pathid=93>

Status New

Detection Date 9/25/2026 4:44:33 PM

Method execution_log, at line 775 of EDS_updated_fixed/app.py, handles an Exception or runtime Error e. During the exception handling code, the application exposes the exception details to ReturnStmt, in method execution_log of EDS_updated_fixed/app.py, line 775.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	781	782
Object	e	ReturnStmt

Code Snippet

File Name EDS_updated_fixed/app.py

Method def execution_log():

```

....
781.     except Exception as e:
782.     return jsonify({'error': str(e)}), 500

```

Information Exposure Through an Error Message\Path 48:

Severity Low

Result State To Verify

Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=94
Status	New
Detection Date	9/25/2026 4:44:33 PM

Method `clear_execution_log_endpoint`, at line 786 of `EDS_updated_fixed/app.py`, handles an Exception or runtime Error `e`. During the exception handling code, the application exposes the exception details to `ReturnStmt`, in method `clear_execution_log_endpoint` of `EDS_updated_fixed/app.py`, line 786.

	Source	Destination
File	<code>EDS_updated_fixed/app.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	792	793
Object	<code>e</code>	<code>ReturnStmt</code>

Code Snippet

File Name `EDS_updated_fixed/app.py`

Method `def clear_execution_log_endpoint():`

```
....  
792.     except Exception as e:  
793.         return jsonify({'error': str(e)}), 500
```

Missing Content Security Policy

Query Path:

Python\Cx\Python Low Visibility\Missing Content Security Policy Version:2

Categories

OWASP ASVS: V14 Configuration

OWASP Top 10 2021: A7-Identification and Authentication Failures

PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Missing Content Security Policy\Path 1:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=81
Status	New
Detection Date	9/25/2026 4:44:33 PM

A Content Security Policy is not explicitly defined within the web-application.

	Source	Destination
File	<code>EDS_updated_fixed/app.py</code>	<code>EDS_updated_fixed/app.py</code>
Line	267	267
Object	<code>ReturnStmt</code>	<code>ReturnStmt</code>

Code Snippet

File Name `EDS_updated_fixed/app.py`

Method `def index():`

```
.....
267. return send_from_directory(BASE_DIR, 'index.html')
```

Missing Content Security Policy\Path 2:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=82
Status	New
Detection Date	9/25/2026 4:44:33 PM

A Content Security Policy is not explicitly defined within the web-application.

	Source	Destination
File	EDS_updated_fixed/app.py	EDS_updated_fixed/app.py
Line	254	254
Object	app	app

Code Snippet

File Name EDS_updated_fixed/app.py
Method app = Flask(__name__, static_folder=STATIC_DIR)

```
.....
254. app = Flask(__name__, static_folder=STATIC_DIR)
```

Improper Resource Shutdown or Release

Query Path:

Python\Cx\Python Low Visibility\Improper Resource Shutdown or Release Version:2

Categories

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Code error
PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description**Improper Resource Shutdown or Release\Path 1:**

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=70
Status	New
Detection Date	9/25/2026 4:44:33 PM

A possible Denial of Service was found in line 73 in EDS_updated_fixed/data_exporter_tool.py file. Not closing connection leaves the server vulnerable to a DoS as the resource are not release properly.

	Source	Destination
File	EDS_updated_fixed/data_exporter_tool.py	EDS_updated_fixed/data_exporter_tool.py
Line	109	109

Object	open	close
--------	------	-------

Code Snippet

File Name EDS_updated_fixed/data_exporter_tool.py
 Method def create_encoder(database_name, table_name, column_name, column_description, start_date, end_date):

```
....
109. open(f"{column_name}_data.csv", 'w').close()
```

Potential Clickjacking on Legacy Browsers

Query Path:

JavaScript\Cx\JavaScript Low Visibility\Potential Clickjacking on Legacy Browsers Version:2

Categories

CWE top 25: CWE top 25

MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data

OWASP ASVS: V05 Validation, Sanitization and Encoding

OWASP Top 10 2021: A8-Software and Data Integrity Failures

SANS top 25: SANS top 25

ASD STIG 5.3: APSC-DV-002330 - CAT II The application must protect the confidentiality and integrity of stored information when required by DoD policy or the information owner.

Description

Potential Clickjacking on Legacy Browsers\Path 1:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=95
Status	New
Detection Date	9/25/2026 4:44:34 PM

The application does not protect the web page EDS_updated_fixed/index.html from clickjacking attacks in legacy browsers, by using framebusting scripts.

	Source	Destination
File	EDS_updated_fixed/index.html	EDS_updated_fixed/index.html
Line	1	1
Object	<	<

Code Snippet

File Name EDS_updated_fixed/index.html
 Method <!DOCTYPE html>

```
....
1. <!DOCTYPE html>
```

Missing CSP Header

Query Path:

JavaScript\Cx\JavaScript Server Side Vulnerabilities\Missing CSP Header Version:1

Categories

ASA Premium: ASA Premium
 OWASP ASVS: V14 Configuration
 OWASP Top 10 2021: A7-Identification and Authentication Failures
 PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Description

Missing CSP Header\Path 1:

Severity	Low
Result State	To Verify
Online Results	https://pkhblc5appsectt5/CxWebClient/ViewerMain.aspx?scanid=1010292&projectid=199&pathid=96
Status	New
Detection Date	9/25/2026 4:44:34 PM

A Content Security Policy is not explicitly defined within the web-application.

	Source	Destination
File	EDS_updated_fixed/static/api-listener.js	EDS_updated_fixed/static/api-listener.js
Line	6	6
Object	body	body

Code Snippet

File Name EDS_updated_fixed/static/api-listener.js
 Method ...RL}/exceptions`,{method:'POST',headers:{'Content-Type':'application/json'},body:JSON.stringify(data)}}); if(!r.ok) throw new Error(`HTTP \${r.status}`); const res = await r.json(); onExceptionAdded(res.exception)...

```
....
6. ...RL}/exceptions`,{method:'POST',headers:{'Content-
Type':'application/json'},body:JSON.stringify(data)}}); if(!r.ok) throw
new Error(`HTTP ${r.status}`); const res = await r.json();
onExceptionAdded(res.exception)...
```

OS Access Violation

Risk

What might happen

An attacker could prepare malicious input data which would cause an access violation, a private data leak, data corruption or a denial of service (DEP violation and application crash)

Cause

How does it happen

The Python's OS module provides a portable interface intended for using host operating system functionality. The interface of the OS module includes operations for creating, deleting and manipulating host files, directories and links. Python's OS module allows arbitrary files access and manipulation. In case an attacker is able to pass a special-crafted input path to the OS module, access violation, information leakage or data corruption may occur.

General Recommendations

How to avoid it

1. Do not perform file manipulation based on inputs received from an untrusted or a user-controlled source.
 2. Make sure path to file which is begin manipulated validated properly:
 - Avoid depending on user input for path to file, if possible.
 - Ensure that path to file is fully canonicalized.
 - Restrict access to file path within a specific directory (sandbox).
 3. Create a white list of files or directories which can be manipulated safely and allow access to only these files or directories.
-

Source Code Examples

Python

Application Removes a File Based on User Input

```
import os
import sys

path = sys.stdin.readline()[:-1]
os.remove(path)
```

Application Validates Path to File Provided by User Input Before Deletion

```
import os
import sys

def is_safe_path(basedir, path):
    return os.path.abspath(path).startswith(basedir)

path = sys.stdin.readline()[:-1]

if not is_safe_path('/tmp/userfiles', path):
    sys.stdout.write('Not allowed!\n')
    sys.exit()

os.remove(path)
```

Reflected XSS All Clients

Risk

What might happen

A successful XSS exploit would allow an attacker to rewrite web pages and insert malicious scripts which would alter the intended output. This could include HTML fragments, CSS styling rules, arbitrary JavaScript, or references to third party code. An attacker could use this to steal users' passwords, collect personal data such as credit card details, provide false information, or run malware. From the victim's point of view, this is performed by the genuine website, and the victim would blame the site for incurred damage.

The attacker could use social engineering to cause the user to send the website modified input, which will be returned in the requested web page.

Cause

How does it happen

The application creates web pages that include untrusted data, whether from user input, the application's database, or from other external sources. The untrusted data is embedded directly in the page's HTML, causing the browser to display it as part of the web page. If the input includes HTML fragments or JavaScript, these are displayed too, and the user cannot tell that this is not the intended page. The vulnerability is the result of directly embedding arbitrary data without first encoding it in a format that would prevent the browser from treating it like HTML or code instead of plain text.

Note that an attacker can exploit this vulnerability either by modifying the URL, or by submitting malicious data in the user input or other request fields.

General Recommendations

How to avoid it

- Fully encode all dynamic data, regardless of source, before embedding it in output.
- Encoding should be context-sensitive. For example:
 - HTML encoding for HTML content
 - HTML Attribute encoding for data output to attribute values
 - JavaScript encoding for server-generated JavaScript
- It is recommended to use the platform-provided encoding functionality, or known security libraries for encoding output.
- Implement a Content Security Policy (CSP) with explicit whitelists for the application's resources only.
- As an extra layer of protection, validate all untrusted data, regardless of source (note this is not a replacement for encoding). Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
 - Data type
 - Size
 - Range
 - Format
 - Expected values
- In the `Content-Type` HTTP response header, explicitly define character encoding (charset) for the entire page.
- Set the `HTTPOnly` flag on the session cookie for "Defense in Depth", to prevent any successful XSS exploits from stealing the cookie.

Source Code Examples

Python

Outputting Unsanitized User Input into an `HttpResponse` in Django

```
def myPage(request):
    name = str(request.GET.get('name'))
    welcomeFormat = '<h1>Welcome, {}!</h1>' #Providing the payload
    name=<script>alert(1)</script> will generate an alert, demonstrating XSS.
    content = welcomeFormat.format(name)
    response = HttpResponse(content)
    return response
```

Outputting HTML Encoded User Input into an HttpRepsonse's Javascript Context in Django, Enabling XSS

```
def myPage(request):
    name = html.escape(str(request.GET.get('name')))
    welcomeFormat = '<script>alert(`Welcome, {}!`)</script>' #Providing the payload
    name=aaaa`-prompt(1)-`1 will generate a prompt, demonstrating XSS.
    content = welcomeFormat.format(name)
    response = HttpResponse(content)
    return response
```

Outputting HTML Encoded User Input into an HttpRepsonse's HTML Context in Django

```
def myPage(request):
    name = html.escape(str(request.GET.get('name')))
    welcomeFormat = '<h1>Welcome, {}!</h1>'
    content = welcomeFormat.format(name)
    response = HttpResponse(content)
    return response
```

Stored XSS

Risk

What might happen

A successful XSS exploit would allow an attacker to rewrite web pages and insert malicious scripts which would alter the intended output. This could include HTML fragments, CSS styling rules, arbitrary JavaScript, or references to third party code. An attacker could use this to steal users' passwords, collect personal data such as credit card details, provide false information, or run malware. From the victim's point of view, this is performed by the genuine website, and the victim would blame the site for incurred damage.

An attacker could use legitimate access to the application to submit modified data to the application's data-store. This would then be used to construct the returned web page, triggering the attack.

Cause

How does it happen

The application creates web pages that include untrusted data, whether from user input, the application's database, or from other external sources. The untrusted data is embedded directly in the page's HTML, causing the browser to display it as part of the web page. If the input includes HTML fragments or JavaScript, these are displayed too, and the user cannot tell that this is not the intended page. The vulnerability is the result of directly embedding arbitrary data without first encoding it in a format that would prevent the browser from treating it like HTML or code instead of plain text.

In order to exploit this vulnerability, an attacker would load the malicious payload into the data-store, typically via regular forms on other web pages. Afterwards, the application reads this data from the data-store, and embeds it within the web page as displayed for another user.

General Recommendations

How to avoid it

- Fully encode all dynamic data, regardless of source, before embedding it in output.
- Encoding should be context-sensitive. For example:
 - HTML encoding for HTML content
 - HTML Attribute encoding for data output to attribute values
 - JavaScript encoding for server-generated JavaScript
- It is recommended to use the platform-provided encoding functionality, or known security libraries for encoding output.
- Implement a Content Security Policy (CSP) with explicit whitelists for the application's resources only.
- As an extra layer of protection, validate all untrusted data, regardless of source (note this is not a replacement for encoding). Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
 - Data type
 - Size
 - Range
 - Format
 - Expected values
- In the `Content-Type` HTTP response header, explicitly define character encoding (charset) for the entire page.
- Set the `HTTPOnly` flag on the session cookie for "Defense in Depth", to prevent any successful XSS exploits from stealing the cookie.

Source Code Examples

Python

Unsanitized Database Inserted into an `HttpResponse` in Django

```
def myPage(request):
    uid = str(request.GET.get('userId'))
    username = User.objects.get(id=uid)
    welcomeFormat = '<h1>Welcome, {}!</h1>' #Setting the username to
    <script>alert(1)</script> will generate an alert, demonstrating stored XSS.
    content = welcomeFormat.format(username)
    response = HttpResponse(content)
    return response
```

Unsanitized Database Inserted into an HttpReponse's Javascript Context in Django, Enabling XSS

```
def myPage(request):
    uid = str(request.GET.get('userId'))
    username = User.objects.get(id=uid)
    welcomeFormat = '<script>alert(`Welcome, {}!`)</script>' #Setting the username to aaaa`-
    prompt(1)-`1 will generate a prompt, demonstrating XSS.
    content = welcomeFormat.format(username)
    response = HttpResponse(content)
    return response
```

HTML Encoded Database Output Inserted into an HttpReponse's HTML Context in Django

```
def myPage(request):
    uid = str(request.GET.get('userId'))
    username = html.escape(User.objects.get(id=uid))
    welcomeFormat = '<h1>Welcome, {}!</h1>' #Setting the username to
    <script>alert(1)</script> will be replaced by encoded alternative
    content = welcomeFormat.format(username)
    response = HttpResponse(content)
    return response
```

Path Traversal

Risk

What might happen

An attacker could define arbitrary file path for the application to use, potentially leading to:

- Stealing sensitive files, such as configuration or system files
- Overwriting files such as program binaries, configuration files, or system files
- Deleting critical files, causing denial of service (DoS).

Cause

How does it happen

The application uses user input in the file path for accessing files on the application server's local disk.

General Recommendations

How to avoid it

1. Ideally, avoid depending on dynamic data for file selection.
2. Validate all input, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
 - Data type
 - Size
 - Range
 - Format
 - Expected values
3. Accept dynamic data only for the filename, not for the path and folders.
4. Ensure that file path is fully canonicalized.
5. Explicitly limit the application to use a designated folder that is separate from the applications binary folder.
6. Restrict the privileges of the application's OS user to necessary files and folders. The application should not be able to write to the application binary folder, and should not read anything outside of the application folder and data folder.

Source Code Examples

Python

Absolute Path Traversal in Flask Application

```
@app.route('/get_file')
def get_file():
    filename = request.args.get('filename')
    if (filename):
        if (os.access(filename, os.R_OK)):
            f = open(filename, 'r')
            response_content = f.read()
            resp = Response(response_content)
            return resp
        else:
            abort(404)
    else:
        abort(404)
```

Relative Path Traversal in Flask Application

```

@app.route('/get_file')
def get_file():
    filename = request.args.get('filename')
    if (filename):
        filename = "public_files/"+filename;
        if (os.access(filename, os.R_OK)):
            f = open(filename, 'r')
            response_content = f.read()
            resp = Response(response_content)
            return resp
        else:
            abort(404)
    else:
        abort(404)

```

Path Traversal Mitigated by Excluding Prefix Directories, using Basename

```

@app.route('/get_file')
def get_file_fixed():
    filename = request.args.get('filename')
    if (filename):
        filename = os.path.basename(filename)
        filename = "public_files/"+filename;
        if (os.access(filename, os.R_OK)):
            f = open(filename, 'r')
            response_content = f.read()
            resp = Response(response_content)
            return resp
        else:
            abort(404)
    else:
        abort(404)

```

CSRF

Risk

What might happen

An attacker could cause the victim to perform any action for which the victim is authorized, such as transferring funds from the victim's account to the attacker's. The action will be logged as being performed by the victim, in the context of their account, and potentially without their knowledge that this action has occurred.

Cause

How does it happen

The application performs some action that modifies database contents, based purely on HTTP request content, and does not require per-request renewed authentication (such as transaction authentication or a synchronizer token), instead relying solely on session authentication. This means that an attacker could use social engineering to cause a victim to browse to a link which contains a transaction request to the vulnerable application, submitting that request from the user's browser. Once the application receives the request, it would trust the victim's session, and would perform the action. This type of attack is known as Cross-Site Request Forgery (CSRF).

A Cross-Site Request Forgery attack relies on the trust between a server and an authenticated client. By only validating the session, the server ensures that a request has emerged from a client's web-browser. However, any website may submit GET and POST requests to other websites, to which the browser will automatically add the session token if it is in a cookie. This cross-site request can then be trusted as arriving from the user's browser, but does not validate that it was their intent was to make this request.

General Recommendations

How to avoid it

Mitigating CSRF requires an additional layer of authentication that is built into the request validation mechanism. This mechanism would attach an additional token that only applies to the given user; this token would be available within the user's web-page, but will not be attached automatically to a request from a different website (e.g. not stored in a cookie). Since the token is not automatically attached to the request, and is not available to the attacker, and is required by the server to process the request, it would be completely impossible for the attacker to fill in a valid cross-site form that contains this token. Many platforms offer built-in CSRF mitigation functionality which should be used, and perform this type of token management under the hood. Alternatively, use a known or trusted library which adds this functionality.

If implementing CSRF protection is required, this protection should adhere to the following rules:

- Any state altering form (Create, Update, Delete operations) should enforce CSRF protection, by adding an CSRF token to every state altering form submission on the client.
 - An CSRF token should be generated, and be unique per-user per-session (and, preferably, per request).
 - The CSRF token should be inserted into the client side form, and be submitted to the server as part of the form request. For example, it could be a hidden field in an HTML form, or a custom header added by a Javascript request.
 - The CSRF token in the request body or custom header must then be verified as belonging to the current user by the server, before a request is authorized and processed as valid.
-

Source Code Examples

Python

Wrapping Flask App with Flask-SeaSurf to Add CSRF Protection

```
app = Flask(__name__)
```

```
csrf = SeaSurf(app)
csrf.init_app(app)
```

Creating a Form Using Flask-WTF's FlaskForm Adds CSRF Hidden Field By Default

```
@app.route('/submit', methods=('GET', 'POST'))
def submit():
    if request.method == 'POST':
        username = request.form.get('user')
        pwd = request.form.get('pwd')
        user = User(username=username, email=pwd)
        db.session.add(user)
        db.session.commit()
        return 'user added'
    else:
        form = FlaskForm()
        return render_template('submit.html', form=form)
```

SSRF

Risk

What might happen

An attacker can abuse this flaw to make arbitrary requests, originating from the application server. This can be exploited to scan internal services; proxy attacks into a protected network; bypass network controls; download unauthorized files; access internal services and management interfaces; and possibly control the contents of requests and even steal server credentials.

Cause

How does it happen

The application accepts a URL (or other data) from the user, and uses this to make a request to another remote server.

However, the attacker can inject an arbitrary URL into the request, causing the application to connect to any server the attacker wants. Thus, the attacker can abuse the application to gain access to services that would not otherwise be accessible, and cause the request to ostensibly originate from the application server.

General Recommendations

How to avoid it

- Do not connect to arbitrary services based on user input.
 - If possible, the application should have the user's browser retrieve the desired information directly.
 - If it is necessary for the application to proxy the request on the server, explicitly whitelist the allowed target URLs, and do not include any sensitive server information.
-

Source Code Examples

JavaScript

Retrieve and Display Status of Internal Services

```
app.get('/status', (req, res) => {  
  
  var status = 'down';  
  axios.get("http://" + req.query.host + '/api/v1/health') // vulnerable  
    .then(response => {  
      status = response.data.status ;  
    })  
    .catch(error => {  
      console.log(error);  
    });  
  return res.json({output : status});  
});
```

Validate User Input Against a List Of Allowed Hosts Or Domains

```
app.get('/status', (req, res) => {  
  
  var status = 'down';  
  var allowed = ["localhost", "10.10.10.1", "10.10.10.3"]
```

```
if (allowed.indexOf(req.query.host) > -1) {  
  return res.json({output : status});  
}  
  
axios.get("http://" + req.query.host + '/api/v1/health')  
  .then(response => {  
    status = response.data.status ;  
  })  
  .catch(error => {  
    console.log(error);  
  });  
return res.json({output : status});  
});
```

Missing HSTS Header

Risk

What might happen

Failure to set an HSTS header and provide it with a reasonable "max-age" value of at least one year may leave users vulnerable to Man-in-the-Middle attacks.

Cause

How does it happen

Many users browse to websites by simply typing the domain name into the address bar, without the protocol prefix. The browser will automatically assume that the user's intended protocol is HTTP, instead of the encrypted HTTPS protocol.

When this initial request is made, an attacker can perform a Man-in-the-Middle attack and manipulate it to redirect users to a malicious web-site of the attacker's choosing. To protect the user from such an occurrence, the HTTP Strict Transport Security (HSTS) header instructs the user's browser to disallow use of an unsecure HTTP connection to the the domain associated with the HSTS header.

Once a browser that supports the HSTS feature has visited a web-site and the header was set, it will no longer allow communicating with the domain over an HTTP connection.

Once an HSTS header was issued for a specific website, the browser is also instructed to prevent users from manually overriding and accepting an untrusted SSL certificate for as long as the "max-age" value still applies. The recommended "max-age" value is for at least one year in seconds, or 31536000.

General Recommendations

How to avoid it

- Before setting the HSTS header - consider the implications it may have:
 - Forcing HTTPS will prevent any future use of HTTP, which could hinder some testing
 - Disabling HSTS is not trivial, as once it is disabled on the site, it must also be disabled on the browser
 - Set the HSTS header either explicitly within application code, or using web-server configurations.
 - Ensure the "max-age" value for HSTS headers is set to 31536000 to ensure HSTS is strictly enforced for at least one year.
 - Include the "includeSubDomains" to maximize HSTS coverage, and ensure HSTS is enforced on all sub-domains under the current domain
 - Note that this may prevent secure browser access to any sub-domains that utilize HTTP; however, use of HTTP is very severe and highly discouraged, even for websites that do not contain any sensitive information, as their contents can still be tampered via Man-in-the-Middle attacks to phish users under the HTTP domain.
 - Once HSTS has been enforced, submit the web-application's address to an HSTS preload list - this will ensure that, even if a client is accessing the web-application for the first time (implying HSTS has not yet been set by the web-application), a browser that respects the HSTS preload list would still treat the web-application as if it had already issued an HSTS header. Note that this requires the server to have a trusted SSL certificate, and issue an HSTS header with a maxAge of 1 year (31536000)
 - Note that this query is designed to return one result per application. This means that if more than one vulnerable response without an HSTS header is identified, only the first identified instance of this issue will be highlighted as a result. If a misconfigured instance of HSTS is identified (has a short lifespan, or is missing the "includeSubDomains" flag), that result will be flagged. Since HSTS is required to be enforced across the entire application to be considered a secure deployment of HSTS functionality, fixing this issue only where the query highlights this result is likely to produce subsequent results in other sections of the application; therefore, when adding this header via code, ensure it is uniformly deployed across the entire application. If this header is added via configuration, ensure that this configuration applies to the entire application.
 - Note that misconfigured HSTS headers that do not contain the recommended max-age value of at least one year or the "includeSubDomains" flag will still return a result for a missing HSTS header.
-

Source Code Examples

Python

Adding HSTS in Django's settings.py

```
SECURE_HSTS_SECONDS = 31536000, SECURE_HSTS_INCLUDE_SUBDOMAINS = True
```

Setting HSTS Header with Code in Django

```
response['Strict-Transport-Security'] = 'max-age=31536000; includeSubDomains'
```

Setting HSTS Header with Code in Flask

```
@app.after_request
def add_header(response):
    response.headers['Strict-Transport-Security'] = 'max-age=31536000; includeSubDomains'
    return response
```

Wrapping a Flask App with Talisman Will Set HSTS Header By Default

```
app = Flask(__name__)
talisman = Talisman(app)
```

Hardcoded Password in Connection String

Risk

What might happen

Hardcoded database passwords expose the application to password leakage, and the database to unauthorized access. If an attacker gains access to the source code (or can decompile the application binaries), the attacker will be able to steal the embedded passwords, and use them to directly access the database. This would enable the attacker to steal secret information, modify sensitive records, or delete important data.

In addition, the password cannot be easily changed when required. In the eventual situation wherein it is a necessity to update the password, a new version of the application would need to be built and deployed to production systems.

Cause

How does it happen

The application has the database password hardcoded in the source code files, and uses this password in a connection string to the database or other server. This password is visible to anyone with access to source code, and cannot be changed without rebuilding or recompiling the application. Even after compilation or deployment, the password and connection string are still present in the binary program files or production environment.

General Recommendations

How to avoid it

- Never hardcode sensitive data, such as database passwords.
- Prefer to avoid requiring an explicit database password at all, instead using OS-integrated system authentication.
- Alternatively, store the password in an encrypted configuration file, and implement a mechanism enabling administrators to change the password. Ensure the file permissions are configured to restrict access to administrators only.
- In particular, if the database supports Integrated Authentication or Kerberos, prefer to use this over explicit credentials for the SQL user. Configure the database connection string with "Trusted_Connection=yes;", or pass `trusted_connection='yes'` as a parameter, according to your database library.
- Alternatively, define the database password and connection parameters in an external configuration file. Protect this configuration file with appropriate permissions and encryption, as available.

Source Code Examples

Python

Hard-Coded Database Password

```
def connect_database:
    db_server = 'dbServer'
    db_database = 'appDb'
    db_user = 'appUser'
    db_password = 'mypass'

    conn = pyodbc.connect(driver='{SQL Server}',
                          server=db_server, database=db_database,
                          user=db_user, password=db_password)

    return conn
```

Connect with Integrated Authentication

```
def connect_database:
    db_server = 'dbServer'
    db_database = 'appDb'

    conn = pyodbc.connect(driver='{SQL Server}',
                          server=db_server, database=db_database,
                          trusted_connection='yes')

    return conn
```

Read Credentials from Encrypted Configuration

```
def connect_database:
    config = configparser.ConfigParser()
    config.read(CONFIG_FILENAME)

    db_server = config.get("database", "db_server")
    db_database = config.get("database", "db_database")
    db_user = config.get("database", "db_user")
    db_password = config.get("database", "db_password")
    db_password = decrypt(db_password)

    conn = pyodbc.connect(driver='{SQL Server}',
                          server=db_server, database=db_database,
                          user=db_user, password=db_password)

    return conn
```

SSRF

Risk

What might happen

An attacker can abuse this flaw to make arbitrary requests, originating from the application server. This can be exploited to scan internal services; proxy attacks into a protected network; bypass network controls; download unauthorized files; access internal services and management interfaces; and possibly control the contents of requests and even steal server credentials.

Cause

How does it happen

The application accepts a URL (or other data) from the user, and uses this to make a request to another remote server.

However, the attacker can inject an arbitrary URL into the request, causing the application to connect to any server the attacker wants. Thus, the attacker can abuse the application to gain access to services that would not otherwise be accessible, and cause the request to ostensibly originate from the application server.

General Recommendations

How to avoid it

- Do not connect to arbitrary services based on user input.
- If possible, the application should have the user's browser retrieve the desired information directly.
- If it is necessary for the application to proxy the request on the server, explicitly whitelist the allowed target URLs, and do not include any sensitive server information.

Source Code Examples

Python

Retrieve and Display Contents of URL

```
def do_GET(self):
    location = urllib.parse.urlparse(self.path)
    query = location.query
    url = urllib.parse.parse_qs(query)['url']

    # This essentially makes the 'url' parameter an open proxy for HTTP requests,
    # allowing HTTP requests to be made into the internal network adjacent to the server
    response = urllib.request.urlopen(url)
    if response.status == 200:
        data = response.read()

        self.send_response(200)
        self.send_header('Content-Type', 'text/html')
        self.send_header('Content-Length', str(len(data)))
        self.end_headers()
        self.wfile.write(data)
```

Validate and Redirect User's Browser

```
def do_GET(self):
```

```
location = urllib.parse.urlparse(self.path)
query = location.query

url = urllib.parse.parse_qs(query)['url']
# Restricted redirection to current domain
if (url.startswith('/') and not url.startswith('//')) or url.startswith("https://" +
location.netloc + "/"):
    self.send_response(302)
    self.send_header('Location', url)
    self.end_headers()
```

Information Exposure Through an Error Message Risk

What might happen

Exposed details about the application's environment, users, or associated data (for example, stack trace) could enable an attacker to find another flaw and help the attacker to mount an attack. This may also leak sensitive data, e.g. passwords or database fields.

Cause

How does it happen

The application handles exceptions in an insecure manner, including raw details directly in the error message. This could occur in various ways: by not handling the exception; printing it directly to the output or file; explicitly returning the exception object; or by configuration. These exception details may include sensitive information that could leak to the users due to the occurrence of the runtime error.

General Recommendations

How to avoid it

- Do not expose exception data directly to the output or users, instead return an informative, generic error message. Log the exception details to a dedicated log mechanism.
 - Any method that could throw an exception should be wrapped in an exception handling block that:
 - Explicitly handles expected exceptions.
 - Includes a default solution to explicitly handle unexpected exceptions.
 - Configure a global handler to prevent unhandled errors from leaving the application.
-

Source Code Examples

Improper Resource Shutdown or Release

Risk

What might happen

An attacker could prepare malicious input data which would cause a denial of service (DEP violation and application crash).

Cause

How does it happen

Web Server Gateway Interface (WSGI) is a Python specification for universal interface between web server and Python web applications. The WSGI specification is specified in PEP 333 and PEP 3333. PEP 3333 (WSGI) claims: "If the iterable returned by the application has a close() method, the server or gateway must call that method upon completion of the current request, whether the request was completed normally, or terminated early due to an application error during iteration or an early disconnect of the browser.". In case a WSGI Python application does not properly close server connections, an attacker could cause a denial of service (DEP violation and application crash).

General Recommendations

How to avoid it

- Close all server connections - Make sure all the WSGI Python application connections are closed properly.
- If the WSGI Python application iterable object has a close() method you have to call it on all execution paths of the program. You can use the Python's contextlib module for these iterable objects.

Source Code Examples

Python

The Application Does Not Properly Close A Server Connection

```
import os
import sys

def run_with_cgi(application):
    environ = dict(os.environ.items())
    environ['wsgi.errors'] = sys.stderr
    environ['wsgi.input'] = sys.stdin
    environ['wsgi.multiprocess'] = True
    environ['wsgi.multithread'] = False
    environ['wsgi.run_once'] = True
    environ['wsgi.url_scheme'] = 'http'
    environ['wsgi.version'] = (1, 0)

    headers_set = [], headers_sent = []

    def write_data(data):
        if not headers_set:
            raise AssertionError("write")
        elif not headers_sent:
            status, response_headers = headers_sent[:] = headers_set
            sys.stdout.write_data('Status: %s\r\n' % status)
            for header in response_headers:
                sys.stdout.write_data('%s: %s\r\n' % header)
            sys.stdout.write_data('\r\n')

    sys.stdout.write_data(data)
```

```

sys.stdout.flush()

def response(status, response_headers, exc_info=None):
    if exc_info:
        try:
            if headers_sent:
                raise exc_info[0], exc_info[1], exc_info[2]
        finally:
            exc_info = None
    elif headers_set:
        raise AssertionError("headers")

    headers_set[:] = [status, response_headers]
    return write_data

result = application(environ, response)
for data in result:
    if data:
        write_data(data)
if not headers_sent:
    write_data('')

```

The Application Invokes the Close() Method of the WSGI Application's iterable Object, If the Method Exists

```

import os
import sys

def run_with_cgi(application):
    environ = dict(os.environ.items())
    environ['wsgi.errors'] = sys.stderr
    environ['wsgi.input'] = sys.stdin
    environ['wsgi.multiprocess'] = True
    environ['wsgi.multithread'] = False
    environ['wsgi.run_once'] = True
    environ['wsgi.url_scheme'] = 'http'
    environ['wsgi.version'] = (1, 0)

    headers_set = [], headers_sent = []

    def write_data(data):
        if not headers_set:
            raise AssertionError("write")
        elif not headers_sent:
            status, response_headers = headers_set[:] = headers_set
            sys.stdout.write_data('Status: %s\r\n' % status)
            for header in response_headers:
                sys.stdout.write_data('%s: %s\r\n' % header)
            sys.stdout.write_data('\r\n')

        sys.stdout.write_data(data)
        sys.stdout.flush()

    def response(status, response_headers, exc_info=None):
        if exc_info:
            try:
                if headers_sent:
                    raise exc_info[0], exc_info[1], exc_info[2]
            finally:
                exc_info = None
        elif headers_set:
            raise AssertionError("headers")

        headers_set[:] = [status, response_headers]
        return write_data

    result = application(environ, response)

```

```
try:
    for data in result:
        if data:
            write_data(data)
    if not headers_sent:
        write_data('')
finally:
    if hasattr(result, 'close'):
        result.close()
```

Missing Content Security Policy

Risk

What might happen

The Content-Security-Policy header enforces that the source of content, such as the origin of a script, embedded (child) frame, embedding (parent) frame or image, are trusted and allowed by the current web-page; if, within the web-page, a content's source does not adhere to a strict Content Security Policy, it is promptly rejected by the browser. Failure to define a policy may leave the application's users exposed to Cross-Site Scripting (XSS) attacks, Clickjacking attacks, content forgery and more.

Cause

How does it happen

The Content-Security-Policy header is used by modern browsers as an indicator for trusted sources of content, including media, images, scripts, frames and more. If these policies are not explicitly defined, default browser behavior would allow untrusted content.

General Recommendations

How to avoid it

Explicitly set the Content-Security-Policy headers for all applicable policy types (frame, script, form, script, media, img etc.) according to business requirements and deployment layout of external file hosting services. Specifically, do not use a wildcard, '*', to specify these policies, as this would allow content from any external resource.

The Content-Security-Policy can be explicitly defined within web-application code, as a header managed by web-server configurations, or within `<meta>` tags in the HTML `<head>` section.

Source Code Examples

PHP

Restricting Content-Security-Policy to Only Obtain Embedded Content from Current Web-Application

```
<?php
    header("Content-Security-Policy: default-src 'none'; script-src 'self'; connect-src
'self'; img-src 'self'; style-src 'self';");
?>
```

Potential Clickjacking on Legacy Browsers

Risk

What might happen

Clickjacking attacks allow an attacker to "hijack" a user's mouse clicks on a webpage, by invisibly framing the application, and superimposing it in front of a bogus site. When the user is convinced to click on the bogus website, e.g. on a link or a button, the user's mouse is actually clicking on the target webpage, despite being invisible.

This could allow the attacker to craft an overlay that, when clicked, would lead the user to perform undesirable actions in the vulnerable application, e.g. enabling the user's webcam, deleting all the user's records, changing the user's settings, or causing clickfraud.

Cause

How does it happen

The root cause of vulnerability to a clickjacking attack, is that the application's web pages can be loaded into a frame of another website. The application does not implement a proper frame-busting script, that would prevent the page from being loaded into another frame. Note that there are many types of simplistic redirection scripts that still leave the application vulnerable to clickjacking techniques, and should not be used.

When dealing with modern browsers, applications mitigate this vulnerability by issuing appropriate Content-Security-Policy or X-Frame-Options headers to indicate to the browser to disallow framing. However, many legacy browsers do not support this feature, and require a more manual approach by implementing a mitigation in Javascript. To ensure legacy support, a framebusting script is required.

General Recommendations

How to avoid it

Generic Guidance:

- Define and implement a Content Security Policy (CSP) on the server side, including a frame-ancestors directive. Enforce the CSP on all relevant webpages.
- If certain webpages are required to be loaded into a frame, define a specific, whitelisted target URL.
- Alternatively, return a "X-Frame-Options" header on all HTTP responses. If it is necessary to allow a particular webpage to be loaded into a frame, define a specific, whitelisted target URL.
- For legacy support, implement framebusting code using Javascript and CSS to ensure that, if a page is framed, it is never displayed, and attempt to navigate into the frame to prevent attack. Even if navigation fails, the page is not displayed and is therefore not interactive, mitigating potential clickjacking attacks.

Specific Recommendations:

- Implement a proper framebuster script on the client, that is not vulnerable to frame-buster-busting attacks.
 - Code should first disable the UI, such that even if frame-busting is successfully evaded, the UI cannot be clicked. This can be done by setting the CSS value of the "display" attribute to "none" on either the "body" or "html" tags. This is done because, if a frame attempts to redirect and become the parent, the malicious parent can still prevent redirection via various techniques.
 - Code should then determine whether no framing occurs by comparing `self === top`; if the result is true, can the UI be enabled. If it is false, attempt to navigate away from the framing page by setting the `top.location` attribute to `self.location`.
-

Source Code Examples

JavaScript

Clickjackable Webpage

```
<html>
  <body>
    <button onclick="clicked();">
      Click here if you love ducks
    </button>
  </body>
</html>
```

Bustable Framebuster

```
<html>
  <head>
    <script>
      if ( window.self.location != window.top.location ) {
        window.top.location = window.self.location;
      }
    </script>
  </head>

  <body>
    <button onclick="clicked();">
      Click here if you love ducks
    </button>
  </body>
</html>
```

Proper Framebusterbusterbusting

```
<html>
  <head>
    <style> html {display : none; } </style>
    <script>
      if ( self === top ) {
        document.documentElement.style.display = 'block';
      }
      else {
        top.location = self.location;
      }
    </script>
  </head>

  <body>
    <button onclick="clicked();">
      Click here if you love ducks
    </button>
  </body>
</html>
```

Missing CSP Header

Risk

What might happen

The Content-Security-Policy header enforces that the source of content, such as the origin of a script, embedded (child) frame, embedding (parent) frame or image, are trusted and allowed by the current web-page; if, within the web-page, a content's source does not adhere to a strict Content Security Policy, it is promptly rejected by the browser. Failure to define a policy may leave the application's users exposed to Cross-Site Scripting (XSS) attacks, Clickjacking attacks, content forgery and more.

Cause

How does it happen

The Content-Security-Policy header is used by modern browsers as an indicator for trusted sources of content, including media, images, scripts, frames and more. If these policies are not explicitly defined, default browser behavior would allow untrusted content.

The application creates web responses, but does not properly set a Content-Security-Policy header.

General Recommendations

How to avoid it

Explicitly set the Content-Security-Policy headers for all applicable policy types (frame, script, form, script, media, img etc.) according to business requirements and deployment layout of external file hosting services. Specifically, do not use a wildcard, '*', to specify these policies, as this would allow content from any external resource.

The Content-Security-Policy can be explicitly defined within web-application code, as a header managed by web-server configurations, or within `<meta>` tags in the HTML `<head>` section.

Source Code Examples

JavaScript

Setting The CSP Header Explicitly

```
app.use(function(req, res, next) {  
  res.setHeader("Content-Security-Policy", "script-src 'self'");  
  return next();  
});
```

Scanned Languages

Language	Hash Number	Change Date
JavaScript	0825762690119392	6/3/2024
VbScript	0386000544005133	6/3/2024
Python	7665804846630023	6/3/2024
Common	3640194344930224	6/3/2024